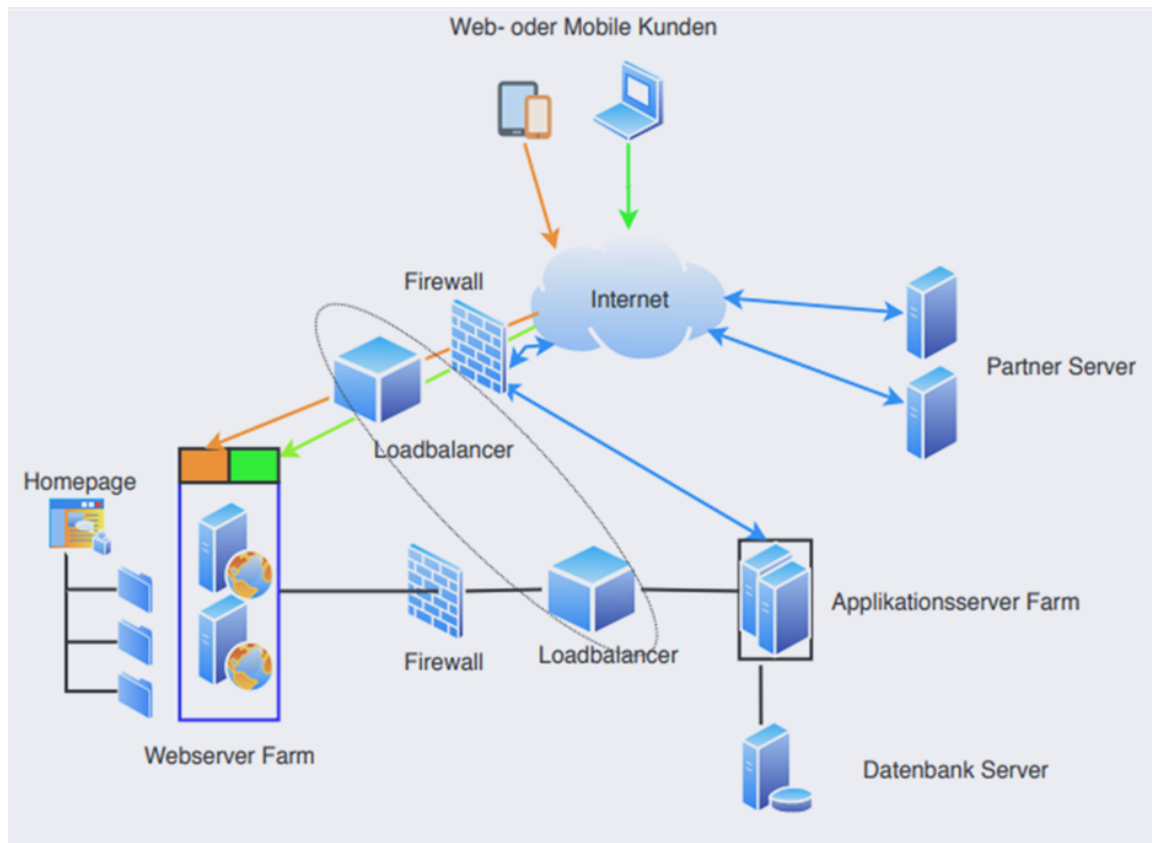




# Programmentwurf

## „Aufbau einer DMZ“

SICHERE UNTERNEHMENSNETZWERKE (SUN)

Prof. Dr. Schneider

## Inhalt

|   |                            |   |
|---|----------------------------|---|
| 1 | Aufgabenstellung .....     | 2 |
| 2 | Abgabe und Bewertung ..... | 3 |

## 1 Aufgabenstellung

Der Programmentwurf besteht im Aufbau einer DMZ (**Demilitarized Zone**) und der Überprüfung der Sicherheit dieser DMZ für eine unternehmenskritische Webanwendung. Die DMZ soll innerhalb **einer virtuellen Maschine** realisiert werden. Die Systeme der DMZ müssen in Form von **Docker** Containern installiert werden. Die Gesamtumgebung muss mit der Software **Containerlab** aufgebaut werden.

### Parameter für die VM

- **vCPU**: 2 Kerne
- **RAM**: 4 GB
- **Disk**: 10 GB (Docker-Images, Logs, Container FS)
- **OS**: Debian + Docker + containerlab

### Anforderung:

Sie implementieren eine DMZ, die den sicheren Betrieb eines **firmeninternen Webservers** nach dem Stand der Technik ermöglicht. Neben **proaktiven Maßnahmen** implementieren Sie auch **reaktive und detektierende Maßnahmen**.

### Zu erreichendes Ergebnis:

- Bereitstellung einer funktionierenden DMZ bestehend aus den folgenden Einzelsystemen: Firewall, Reverse-Proxy, IDS, WAF und Webserver.
- Separates internes Netz (Client) das über internen Router angebunden ist.
- Separates internes Netz (Backend) das über eine Firewall angebunden ist.
- Remote Office-Standort (nur Clients).
- VPN-Verbindung vom Remote Office Standort zum Firmennetzwerk.
- Internet-Netzwerk das über eine Edge Firewall vom internen und von der DMZ erreichbar ist.
- SIEM-System im Backend.
- Die Funktionsfähigkeit der Systeme und deren Interaktion wird durch Tests nachgewiesen.

- Die Sicherheits-Systeme sind mittels Sicherheitsmaßnahmen gegenüber Angriffen gehärtet, deren Wirksamkeit überprüft wird.
- Mittels selbst erstellter Cyber-Angriffe, die aus dem Internet (Internet-Netzwerk) und von intern (Client-Netzwerk) ausgeführt werden, überprüfen Sie die Sicherheit der DMZ und des kritischen Webservers.
- Angriffe werden erkannt und an ein zentrales SIEM-System im Backend-Netzwerk gemeldet und dort übersichtlich in Form von Dashboards für ein SOC visualisiert.

Zur Erstellung der DMZ bilden Sie [2-er Teams](#). Jedes Team entwirft seine eigene DMZ und installiert die dazugehörigen Systeme.

## 2 Abgabe und Bewertung

Der Programmentwurf ist schriftlich zu dokumentieren. Die technischen Inhalte sollen nachvollziehbar, strukturiert und gut verständlich beschrieben werden. Zur Veranschaulichung sind geeignete Diagramme sowie relevante Auszüge aus dem Source Code einzubinden.

Die erstellte VM muss in der **virtuellen Laborumgebung der DHBW** installiert werden. Der **Funktionsfähigkeit, Wirksamkeit und Vollständigkeit** wird im Rahmen einer Live-Demo / Abnahme mittels der VM im Labor der DHBW präsentiert. Die Präsentation erfolgt abwechselnd durch die Teilnehmerinnen und Teilnehmer einer Gruppe.

In der Live-Demo sollen sowohl die **Qualität** des Programmentwurfs, insbesondere der technische Schwierigkeitsgrad, als auch die **Quantität**, also die Vollständigkeit der Umsetzung, deutlich werden. Die Demonstration muss verständlich durch den Programmentwurf führen und die eingesetzten Methoden und Entscheidungen erläutern sowie die erzielten Ergebnisse anschaulich darstellen.

Die Dokumentation, der erstellte Source Code sowie die Präsentationsfolien sind final in den Moodle-Kurs hochzuladen.

## Bewertungskriterien: Funktionsnachweis/Abnahme des Programmentwurfes

(50 Punkte)

| Bewertungskriterium                  | Beschreibung                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Quantität / Vollständigkeit</b>   | <ul style="list-style-type: none"> <li>Die DMZ sowie die angebundenen Netzwerke, insbesondere Internet, Client-Netz und Backend-Netz, sind vollständig umgesetzt und nachvollziehbar dokumentiert.</li> <li>Die wesentlichen Systemkomponenten sind integriert und in der Live-Demo sichtbar.</li> <li>Es werden mindestens drei Cyberangriffe demonstriert, mit denen die Sicherheitsmechanismen des Systems überprüft und bestätigt werden.</li> <li>Erkannte Angriffe werden innerhalb 1s im Monitoring-System für einen Operator verständlich angezeigt.</li> </ul> |
| <b>Qualität / Funktionsfähigkeit</b> | <ul style="list-style-type: none"> <li>Das System beziehungsweise die Software läuft während der Live-Präsentation stabil und ohne wesentliche Fehler.</li> <li>Die gezeigten Angriffe, Gegenmaßnahmen und Teilsysteme sind funktionsfähig und fachlich plausibel.</li> <li>Die Live-Angriffe auf die DMZ weisen einen hohen technischen Schwierigkeitsgrad auf und zeigen ein vertieftes Verständnis der Sicherheitsmechanismen.</li> <li>Grenzen des Programmentwurfes, zukünftige Verbesserungen werden transparent erläutert.</li> </ul>                            |
| <b>Zeitvorgabe</b>                   | <ul style="list-style-type: none"> <li>Die Präsentation darf 15 Minuten nicht überschreiten. Bei Zeitüberschreitung werden pro angefangener Minute 3 Punkte abgezogen. Beispiele: 16:00 Minuten = 3 Punkte Abzug, 17:00 Minuten = 6 Punkte Abzug.</li> </ul>                                                                                                                                                                                                                                                                                                            |
|                                      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

## Bewertungskriterien: Dokumentation, Design, Methoden, Installation

(50 Punkte)

| Bewertungskriterium      | Beschreibung                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|--------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Methodenkompetenz</b> | <ul style="list-style-type: none"> <li>• Das Vorgehen beim Entwurf, bei der Umsetzung, beim Test und bei der Integration der Systeme beziehungsweise der Software wird nachvollziehbar dargestellt.</li> <li>• Entscheidungen im Entwicklungsprozess werden begründet.</li> <li>• Eingesetzte Methoden werden erläutert.</li> <li>• Die Gruppe zeigt, dass sie planvoll, strukturiert und methodisch gearbeitet hat.</li> </ul>                                                                                                                                                                  |
| <b>Dokumentation</b>     | <ul style="list-style-type: none"> <li>• Die Dokumentation besitzt einen professionellen Aufbau mit Titelblatt, Inhaltsverzeichnis, Einleitung, Zielsetzung, theoretischen Grundlagen, Design, eingesetzte Methoden, Test und Evaluation, Fazit sowie Quellen- und Hilfsmittelverzeichnis.</li> <li>• Einsatzzweck, Architektur und Funktionsweise der Software und der einzelnen Systeme werden fachlich präzise und verständlich beschrieben.</li> <li>• Diagramme veranschaulichen Funktionsweise, Datenflüsse, Netzwerkstruktur, Sicherheitsmechanismen und zentrale Komponenten.</li> </ul> |
| <b>Design</b>            | <ul style="list-style-type: none"> <li>• Das technische Design ist fachlich begründet, konsistent und passend zum Einsatzzweck. Die gewählte Architektur, die Netzsegmentierung, die</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                  |

|                                        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|----------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                        | <p>Sicherheitsmechanismen und die eingesetzten Technologien werden nachvollziehbar hergeleitet. Risiken, Annahmen, Grenzen der Lösung und mögliche Verbesserungen werden angemessen reflektiert.</p>                                                                                                                                                                                                                                                                                     |
| <b>Funktionsfähigkeit</b>              | <ul style="list-style-type: none"> <li>• Die Wirksamkeit und Funktionalität der Sicherheitsmaßnahmen werden durch geeignete Tests, Messergebnisse, Screenshots, Protokolle oder andere Nachweise belegt.</li> <li>• Die Testfälle werden nachvollziehbar beschrieben, die Ergebnisse fachlich eingeordnet und mit der Zielsetzung des Programmentwurfs verknüpft.</li> </ul>                                                                                                             |
| <b>Installation</b>                    | <ul style="list-style-type: none"> <li>• Die Installationsanleitung ist verständlich, vollständig und praktisch nachvollziehbar.</li> <li>• Die Installation basiert auf automatisierten Skripten, zum Beispiel *.yaml, *.sh oder vergleichbaren Dateien, die zusammen mit der Abgabe im Moodle-Kurs bereitgestellt werden.</li> <li>• Voraussetzungen, Konfigurationsschritte, Start der Systeme, Tests der Installation und mögliche Fehlerquellen werden klar beschrieben.</li> </ul> |
| <b>Inhalts- und Quellenverzeichnis</b> | <ul style="list-style-type: none"> <li>• Die Dokumentation enthält ein vollständiges Inhaltsverzeichnis sowie ein nachvollziehbares Quellenverzeichnis.</li> <li>• Verwendete Hilfsmittel wie zum Beispiel Tools, KI-Werkzeuge werden vollständig angegeben und deren Einsatz angemessen erläutert.</li> </ul>                                                                                                                                                                           |
| <b>Selbstständigkeitserklärung</b>     | <ul style="list-style-type: none"> <li>• Die Selbstständigkeitserklärung ist vollständig enthalten und von allen Gruppenteilnehmerinnen und Gruppenteilnehmern unterschrieben.</li> </ul>                                                                                                                                                                                                                                                                                                |

